

Project MAYA Phase 5 Security Self-Review Report

Broker, Standard OAuth, Token Lifecycle, and CodeQL Remediation Evidence

Report date: July 7, 2026

Prepared by: Project MAYA product owner / solo developer

Reviewed commit: 25e5cdd8889f1824166ff0ecef1228163040b6f5

Classification: Product security self-review artifact. This report is intended to support the Product Spec V2 Phase 5 closure record while clearly distinguishing self-review from independent third-party assurance.

Executive Summary

Project MAYA Phase 5 implemented broker protocol, Standard Google/Slack OAuth support, token lifecycle handling, mock broker conformance, and model-proxy readiness checks. This self-review records the security posture after implementation and remediation.

Conclusion: Phase 5 is product-implementation complete and internally security-reviewed. External independent security review is deferred and remains a pre-production or customer-readiness gate.

Evidence Snapshot

Evidence Area	Recorded Result
Reviewed commit	25e5cdd8889f1824166ff0ecef1228163040b6f5
Product scope	Product Spec V2 Phase 5 broker and Standard OAuth implementation
Code scanning	0 open GitHub CodeQL alerts after remediation and documented false-positive dismissal
Secret scanning	Enabled in GitHub repository settings, per operator confirmation
Dependabot alerts	Enabled in GitHub repository settings, per operator confirmation
Focused tests	42 passed, 1 skipped in focused security/regression set
Phase 5 status	Implementation complete; self-review complete; third-party review deferred

Review Scope

- Broker protocol contracts, signed request/response handling, nonce and replay controls.
- Standard broker-assisted OAuth surfaces for Google and Slack.
- Token status, refresh, revocation, storage metadata, and secret-safe output behavior.
- Broker-disabled and setup-only behavior boundaries.
- Telegram broker-mode rejection and customer-owned credential policy.
- Maya-managed model billing readiness, limited to readiness and policy boundaries.

Security Controls Reviewed

- Local-first authority remains with customer-controlled files, memory, governance, and secrets.
- Raw tokens are not stored in configuration, logs, fixtures, or CLI output.
- Secret references and redacted lifecycle metadata are used for operator-visible status.
- PKCE, state, nonce, expiry, and replay-rejection behavior are covered by tests.
- Broker mode is constrained to runtime, setup_only, or disabled.
- Phase 5 does not claim production installer, automatic update, Telegram OAuth, or broker ownership of local memory or files.

Automated Security Evidence

- GitHub CodeQL code scanning has 0 open alerts as of the refreshed alert export.
- Two CodeQL alerts were dismissed as false positives with documented rationale after code hardening and regression coverage.
- Secret scanning is enabled in GitHub repository settings, per operator confirmation.
- Dependabot alerts are enabled in GitHub repository settings, per operator confirmation.
- Focused security/regression tests passed: 42 passed, 1 skipped.

Dismissed CodeQL False Positives

- Alert 53: CLI output sink. Dismissal rationale: payload output is emitted only after `_redact_payload_for_output` sanitizes sensitive fields; regression tests cover secret redaction.
- Alert 34: Hindsight env write. Dismissal rationale: env write is restricted to allowlisted parsed integer timeout settings only; secret-shaped keys are filtered and regression tests cover the boundary.

Residual Risks And Deferred Work

- This report is a self-review and is not an independent third-party audit.
- Production customer deployment should still receive independent review of broker/OAuth and token-lifecycle code.
- Live provider behavior should be retested when real Google and Slack tenant credentials are configured.
- Phase 6 installer, update, rollback, and platform support claims remain out of scope.
- False-positive dismissals should be revisited if the redaction or env-write boundaries change.

Closure Statement

Based on the reviewed implementation, tests, code-scanning state, and remediation record, Phase 5 may be treated as implementation complete and internally security-reviewed. The external independent security review remains deferred until resources, customer requirements, or production assurance needs make it feasible.

Reviewer attestation

I attest that this self-review accurately represents the Phase 5 security evidence available as of the report date.
This is not an independent third-party audit.

Reviewer name	
Role	
Date	
Signature	